

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 02/03/2026

Actividad y unidad: U5 AI: Proyecto Integrador: Desarrollo ágil con
consideraciones de ciberseguridad

Clase: Seguridad de software.

Maestría en Ciberseguridad.

INTRODUCCIÓN.

El desarrollo de software ha existido desde la masificación y comercialización de la informática; sin embargo, su diseño, construcción e implementación han evolucionado constantemente para adaptarse a los requerimientos del mercado. En sus inicios, era común trabajar con metodologías poco claras que generaban grandes vacíos de comunicación entre los equipos de desarrollo y los clientes. Durante esta etapa temprana, la seguridad de la información no se contemplaba como un pilar fundamental para agregar valor a los productos y servicios. El enfoque casi exclusivo de la industria era entregar productos funcionales, dejando en segundo plano áreas críticas como la ciberseguridad, la productividad y la optimización de recursos computacionales.

Hoy en día, gracias al conocimiento y adopción de metodologías estructuradas como el Ciclo de Vida de Desarrollo de Software (SDLC) y la integración de filosofías como DevOps (y DevSecOps), es posible construir productos mucho más seguros y eficientes. Si bien la implementación de estas prácticas y controles de seguridad puede requerir una mayor cantidad de recursos computacionales, el avance y abaratamiento de las capacidades de memoria y procesamiento del hardware actual permiten soportarlos sin comprometer el rendimiento general.

Tomando como base esta evolución hacia el desarrollo seguro desde el diseño, el presente proyecto integrador aplica las fases del ciclo de vida de desarrollo ágil a un Sistema Web de Gestión de Portafolios de Inversión. El objetivo es documentar la construcción de requerimientos, el análisis de riesgos, el modelado y las estrategias de mitigación necesarias para proteger la información financiera de los usuarios frente a las amenazas actuales.

DESARROLLO.

Fase 1: Construcción de requerimientos epopeyas y casos de abuso.

Tabla 1.1: Epopeya de Autenticación Segura

EPOPEYA	HISTORIAS DE USUARIO	TAREA POR IMPLEMENTAR
Como usuario quiero un sistema de control de acceso robusto para proteger la información confidencial de mi portafolio de inversiones.	Como cliente quiero ingresar al sistema mediante un usuario, una contraseña fuerte y un segundo factor de autenticación (2FA).	- Diseño de la historia y modelo de datos seguro. - Implementación de algoritmos de hashing para contraseñas (ej. Bcrypt). - Integración de token de autenticación (2FA). - Pruebas de validación contra ataques de fuerza bruta.

Tabla 1.2: Epopeya de Visualización e Integridad de Datos

EPOPEYA	HISTORIAS DE USUARIO	TAREA POR IMPLEMENTAR
Como usuario quiero un panel de control seguro donde pueda consultar el rendimiento actualizado de mis fondos de inversión, FIBRAS y criptoactivos.	Como cliente quiero visualizar el saldo y los rendimientos de mis instrumentos financieros garantizando que la información viaje por un canal cifrado.	- Diseño de la interfaz del dashboard. - Implementación de cifrado en tránsito (configuración estricta de TLS/HTTPS). - Validación de controles de autorización (para evitar escalamiento de privilegios). - Pruebas de vulnerabilidad contra inyección SQL y XSS.

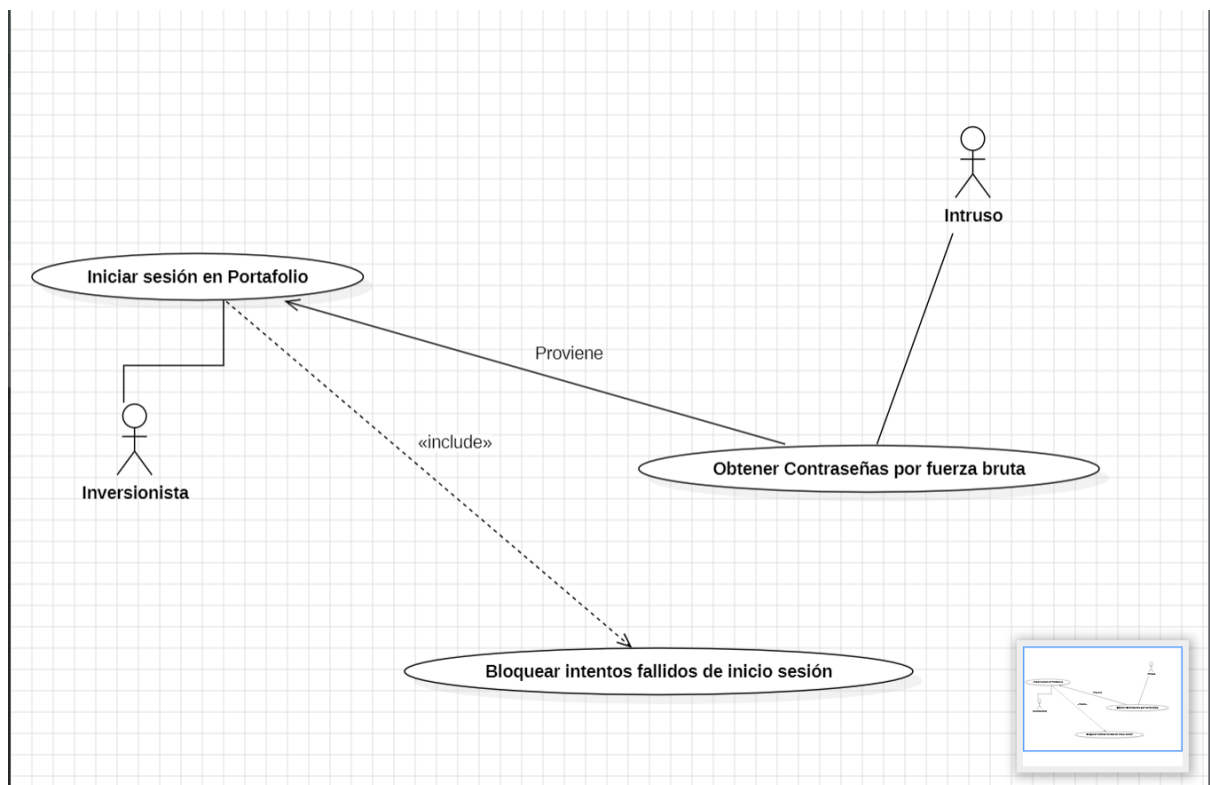
Tabla 1.3: Epopeya de Registro de Transacciones Seguras.

EPOPEYA	HISTORIAS DE USUARIO	TAREAS POR IMPLEMENTAR
Como usuario quiero registrar los movimientos de mi capital (aportaciones y retiros) garantizando la trazabilidad e integridad de cada operación.	Como cliente quiero capturar los montos de mis operaciones mediante un formulario que valide los datos de entrada para evitar manipulación de parámetros.	- Diseño del formulario transaccional. - Implementación de validación estricta de entradas (tanto en cliente como en servidor). - Desarrollo de un registro de auditoría (<i>logs</i>) inalterable para cada movimiento. - Pruebas de manipulación de parámetros e inyección de comandos.

CASOS DE ABUSO.

Caso de Abuso 1: Ataque de Fuerza Bruta al Login

En este escenario, el intruso intenta adivinar las contraseñas de los inversionistas para entrar a sus portafolios.



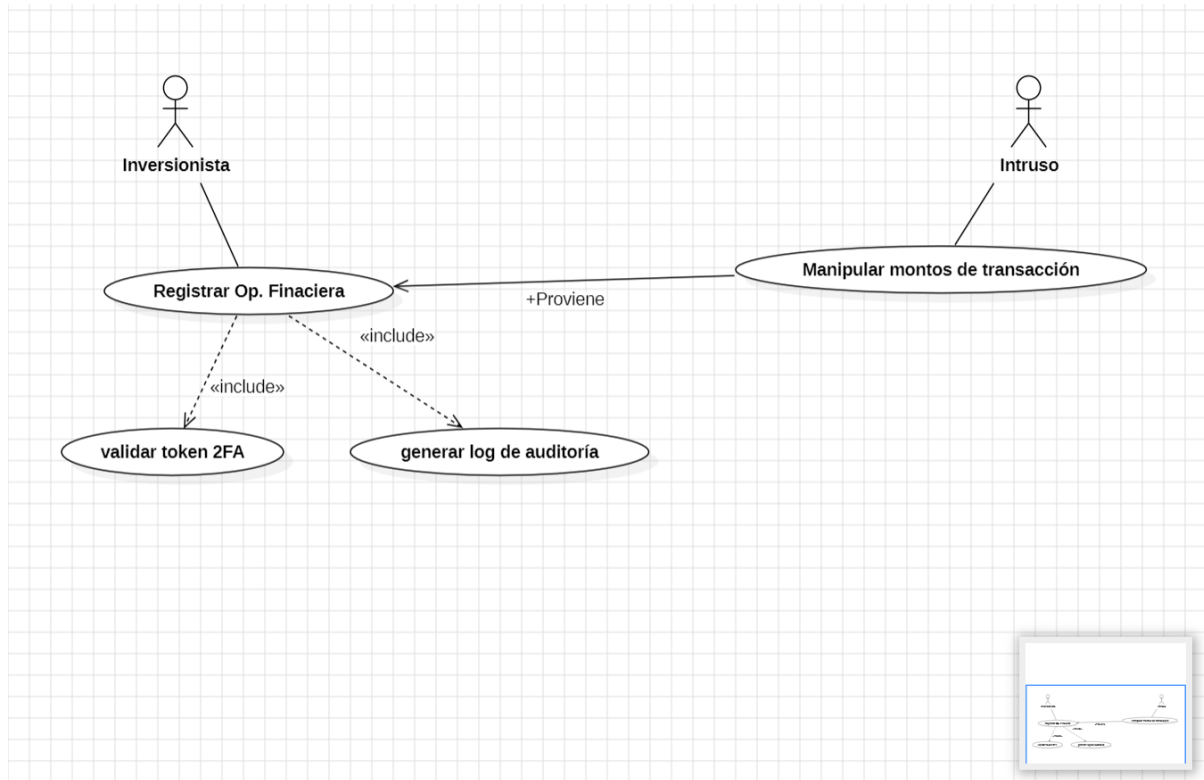
Descripción del modelo: En el diagrama presentado se modela la interacción principal del **Inversionista** al acceder al sistema mediante el caso de uso "Iniciar sesión en Portafolio". Paralelamente, se introduce un actor malicioso (**Intruso**) cuyo objetivo es vulnerar este mecanismo de acceso. El intruso ejecuta el caso de abuso "Obtener contraseñas por fuerza bruta", el cual representa una amenaza directa (indicada por la relación *Proviene*) al proceso de autenticación legítimo.

Para mitigar este riesgo desde la fase de diseño, se establece que el inicio de sesión debe estar condicionado por controles de seguridad restrictivos. Esto se representa mediante la relación de inclusión (<<include>>) hacia el caso de uso "Bloquear intentos fallidos de inicio sesión". De esta manera, se garantiza que el sistema contará con un mecanismo de defensa activo frente a ataques automatizados que busquen adivinar credenciales, protegiendo la confidencialidad del portafolio del usuario.

Descripción del modelo: En este modelo se ilustra la interacción del Inversionista al ejecutar el caso de uso legítimo "Consultar rendimiento del portafolio". Paralelamente, el Intruso busca explotar esta funcionalidad mediante el caso de abuso "Robar información financiera" (por ejemplo, a través de ataques de inyección SQL o interceptación de tráfico Man-in-the-Middle). Esta acción maliciosa representa un riesgo directo a la confidencialidad de los datos del cliente, lo cual se denota con la relación Proviene.

Para contrarrestar esta amenaza desde el diseño arquitectónico del software seguro, el sistema exige que la consulta de saldos integre obligatoriamente dos controles de seguridad (<<include>>): "Cifrar información en tránsito" (garantizando el uso de protocolos seguros como HTTPS/TLS) y "Validar parámetros de consulta" (sanitizando las entradas para evitar la manipulación de la base de datos). Con estos controles, se asegura la integridad y privacidad de la información financiera del usuario.

Caso de abuso 3: Manipulación de transacciones financieras.



Descripción del modelo: Este diagrama expone el escenario donde el Inversionista ejecuta el caso de uso "Registrar operación financiera" para gestionar los fondos de su portafolio. El riesgo inherente se modela a través del actor malicioso (Intruso), quien intenta ejecutar el caso de abuso "Manipular montos de transacción" (por ejemplo, alterando los parámetros de la petición HTTP). Esta acción Proviene del intruso y amenaza la integridad de los datos transaccionales.

Para asegurar la aplicación, el caso de uso legítimo incorpora (<<include>>) dos barreras arquitectónicas: la primera es "Validar token de autorización (2FA)", exigiendo confirmación del usuario para movimientos de capital; la segunda es "Generar log de auditoría", garantizando que exista un registro inalterable de quién, cómo y cuándo se realizó la operación, facilitando así la trazabilidad y el cumplimiento normativo.

3. Ajuste de historias de usuario.

Tabla 2.1 Ajuste de historia de usuario HU01 (Autenticación)

HU01: Iniciar sesión segura en el portafolio.

Como: Inversionista del sistema.

Quiero: Autenticarme en la plataforma web.

Para: Acceder al panel de control de mi portafolio de inversión.

Condiciones:

Cuando el usuario ingrese sus credenciales correctas -> Entonces, el sistema debe solicitar un token de doble factor (2FA) antes de dar acceso.

Cuando se detecten 3 intentos fallidos de contraseña -> Entonces, el sistema bloqueará temporalmente la cuenta por 15 minutos para evitar ataques de fuerza bruta.

Cuando el usuario deje la sesión inactiva por 10 minutos -> Entonces, el token de sesión (JWT) debe expirar automáticamente.

Tabla 2.2 Ajuste de historia de usuario HU02 (Consulta)

HU02: Consultar rendimiento del portafolio.

Como: Inversionista del sistema.

Quiero: Visualizar el saldo de mis fondos, FIBRAs y criptoactivos.

Para: Monitorear mis ganancias.

Condiciones:

Cuando el sistema consulte la base de datos -> Entonces, debe validar y parametrizar la consulta para evitar inyecciones SQL.

Se requiere que la información viaje cifrada mediante protocolo HTTPS (TLS 1.3).

Tabla 2.3 Ajuste de historia de usuario HU03 (Transacciones)

HU03: Registrar operación financiera.

Como: Inversionista del sistema.

Quiero: Registrar aportaciones o retiros de capital.

Para: Mantener actualizado mi balance financiero.

Condiciones:

Cuando se envíe el formulario de transacción -> Entonces, el backend debe validar que los montos no hayan sido alterados o vengan con caracteres inválidos.

Cuando la transacción sea exitosa -> Entonces, se debe generar un registro inalterable en el log de auditoría del servidor.

4. Planeación de Sprints

Sprint 1 (Semanas 1-2): Autenticación y Visualización Segura

Desarrollo de HU01 (Login, cifrado de contraseñas, integración 2FA y políticas de bloqueo).

Desarrollo de HU02 (Dashboard de saldos, parametrización de consultas a BD, configuración de certificados SSL/TLS).

Sprint 2 (Semanas 3-4): Transaccionalidad y Auditoría

Desarrollo de HU03 (Formularios de aportación/retiro, sanitización de inputs).

Implementación del sistema de logging centralizado para auditoría de movimientos financieros.

Fase 2: Análisis de riesgo.

Tabla 3. Matriz de riesgos del Sistema de Portafolios de Inversión

Id .	Desc. Riesgo	Tipo Riesgo	Acciones de prevención	Clasificación de riesgo	Acción de corrección	Responsable
R01	Intercepción de credenciales o saldos durante la transmisión de datos (Man-in-the-Middle).	Seguridad de red / Confidencialidad	Implementación estricta de HSTS y cifrado de canal con TLS 1.3 para toda comunicación.	Alto (0.80)	Bloqueo inmediato de peticiones HTTP en texto plano y rotación de certificados.	Arquitecto de seguridad
R02	Inyección SQL en formularios de consulta para acceder a	Seguridad de aplicación / Integridad	Uso de consultas parametrizadas (Prepared Statements) en el	Crítico (0.95)	Sanitización de entradas afectadas, revisión de código estático y parcheo	Desarrollador Backend / DevSec Ops

	portafolios de otros clientes.		backend y validación estricta de inputs.		de la vulnerabilidad.	
R03	Vulneración de cuentas mediante ataques automatizados de fuerza bruta al login.	Control de acceso / Disponibilidad	Implementación de reCAPTCHA, bloqueo tras 3 intentos fallidos y exigencia de 2FA.	Medio (0.50)	Restablecimiento obligatorio de contraseñas comprometidas y notificación de alerta al inversionista.	Administrador del Sistema
R04	Manipulación de montos durante el registro de aportaciones o retiros de capital.	Fraude transaccional / Integridad	Validación de integridad mediante tokens anti-CSRF y firmas digitales en las peticiones.	Crítico (0.90)	Reversión de la transacción anómala, auditoría de logs y suspensión preventiva de la cuenta.	Oficial de Cumplimiento / SecOps

Fase 3. Fase de diseño.

1. Tarjeta CRC: Usuario

Nombre de la clase: Usuario	
Responsabilidad	Colaboración.
• Almacenar datos personales del inversionista. • Gestionar el estado de la cuenta (activa, suspendida, bloqueada por seguridad). • Mantener las preferencias y configuraciones del cliente.	• Login • Portafolio • Transacción

2. Tarjeta CRC: Login.

Nombre de la clase: Login	
Responsabilidad	Colaboración.
• Captura e ingreso seguro de credenciales.	• Usuario • Auditoria

• Validar el hash de la contraseña contra la base de datos. • Solicitar y validar el token de doble factor (2FA). • Gestionar y aplicar bloqueos temporales por intentos de fuerza bruta. • Generar token de sesión seguro (JWT) tras autenticación exitosa.	
---	--

3. Tarjeta CRC: Portafolio.

Nombre de la clase: Portafolio	
Responsabilidad	Colaboración.
• Consultar saldo y	• Usuario

posiciones de instrumentos financieros (ej. fondos de inversión, FIBRAs o criptoactivos). • Calcular los rendimientos históricos y actuales. • Asegurar la parametrización de las consultas a la base de datos para prevenir inyecciones SQL. • Enviar la información financiera al frontend de manera cifrada.	• Transacción.
--	--

4. Tarjeta CRC: Transacción.

Nombre de la clase: Transacción.**Responsabilidad**

- Registrar nuevas aportaciones de capital o solicitudes de retiro.
- Sanitizar los montos y datos de entrada (evitar caracteres maliciosos o manipulación de parámetros).
- Exigir re-autenticación o firma digital para aprobar retiros de fondos.

Colaboración.

- Usuario
- Portafolio.

5. Tarjeta CRC: Auditoría.

Nombre de la clase: Auditoría.	
Responsabilidad	Colaboración.
• Registrar eventos críticos de seguridad (inicios de sesión fallidos, bloqueos de cuenta). • Registrar operaciones financieras exitosas o rechazadas. • Mantener la inmutabilidad de los registros (<i>logs</i>) para análisis forense y cumplimiento normativo.	• Login. • Transacción.

Fase 4: Codificación y pruebas.

1. Acciones complementarias a los marcos de seguridad:

Para garantizar la seguridad del Sistema de Portafolios de Inversión, se implementarán acciones complementarias a los marcos de desarrollo tradicionales, divididas en análisis estático y dinámico:

Análisis Estático (SAST): Se integrará SonarQube en el pipeline de CI/CD para escanear el código fuente en busca de vulnerabilidades (como uso de funciones obsoletas o credenciales hardcodeadas) antes de que el código llegue a producción.

Análisis Dinámico (DAST): Para la evaluación de vulnerabilidades de la aplicación web en tiempo de ejecución, utilizaremos Burp Suite (de PortSwigger). Esta herramienta nos permitirá realizar pruebas de penetración manuales y automatizadas, interceptando el tráfico para intentar ataques de Inyección SQL, manipulación de parámetros y validación de la gestión de sesiones.

Análisis de Composición (SCA): Se usará OWASP Dependency-Check para auditar que las librerías de terceros utilizadas en el proyecto no tengan vulnerabilidades públicas conocidas (CVEs).

2. Pruebas a historias de usuario.

Historia de usuario	Prueba por realizar
HU01: Iniciar sesión segura	• Ingresar credenciales correctas y validar generación de token JWT. • Ingresar contraseña incorrecta 3 veces para validar el bloqueo de cuenta. • Intentar acceder al dashboard sin el token de doble factor (2FA). • Dejar la sesión inactiva por 10 minutos y verificar la expiración.

Historia de usuario	Prueba por realizar
HU02: Consultar rendimiento	• Ingresar caracteres especiales (ej. ' OR 1=1 --) en los filtros de búsqueda para probar Inyección SQL. • Interceptar la petición y modificar el ID del portafolio para intentar ver el saldo de otro usuario (Escalamiento de privilegios).

Historia de usuario	Prueba por realizar
HU03: Registrar operación	• Registrar una aportación de capital válida. • Interceptar la transacción y enviar un monto negativo para probar la sanitización de inputs. • Enviar la petición de retiro sin el token anti-CSRF para verificar que el servidor rechace la

	operación.
--	------------

Tabla 6. Prueba de caja negra - Autenticación y Bloqueo.

Número	Acción/Descripción	Resultado
1	Acción: Pulsar el botón de ingreso dejando los campos de usuario y contraseña en blanco. Descripción: El sistema debe validar que los campos no estén vacíos antes de enviar la petición.	Satisfactorio. Se visualizan mensajes de "Campo requerido" en el formulario.
2	Acción: Digitar datos de autenticación incorrectos. Descripción: Se envían credenciales erróneas para validar el manejo de errores.	Satisfactorio. Se visualiza el mensaje genérico "Usuario o contraseña incorrectos" sin revelar cuál de los dos falló.
3	Acción: Digitar datos incorrectos 3 veces consecutivas.	Satisfactorio. La cuenta se bloquea temporalmente y se

	Descripción: Prueba de mitigación contra ataques de fuerza bruta.	muestra el mensaje "Cuenta bloqueada por seguridad. Intente en 15 minutos".
4	Acción: Pulsar el botón de ingreso con datos válidos y token 2FA correcto. Descripción: El sistema autentica al inversionista.	Satisfactorio. La aplicación direcciona al usuario al dashboard de su portafolio.
Resumen de resultados	La interfaz de ingreso permite acceder al sistema de forma segura cuando los datos y el doble factor son correctos. El sistema mitiga ataques de fuerza bruta bloqueando la cuenta tras múltiples intentos fallidos y no revela información sensible en los mensajes de error.	

Fase 5: Implementación y seguimiento.

Fase de implementación

Tabla 7. Acciones de mitigación de riesgos por capa

Capa	Acción de mitigación de riesgos
Físico	• Controles de acceso biométrico estrictos para el personal que ingresa al centro de datos donde se alojan los servidores. • Monitoreo mediante circuito cerrado de televisión (CCTV) 24/7 y sistemas de supresión de incendios.
Red	• Implementación de una arquitectura de red segmentada con una DMZ para los servidores web. • Configuración de firewalls perimetrales y auditorías periódicas de puertos abiertos (utilizando herramientas como Nmap) para cerrar accesos innecesarios. • Restricción de acceso por IP a los paneles de administración.
Host	• Hardening (endurecimiento)

	del sistema operativo de los servidores, deshabilitando servicios por defecto que no se utilicen. • Gestión automatizada y obligatoria de parches de seguridad para el SO y los servicios subyacentes.
Aplicación	• Despliegue de un WAF (Web Application Firewall) para bloquear tráfico web malicioso. • Ejecución periódica de escáneres de vulnerabilidades web (integrando herramientas como Wapiti en el entorno de pruebas) para detectar fallos antes de pasar a producción.
Datos	• Cifrado de datos en reposo (AES-256) para proteger la base de datos que contiene la información de los portafolios y saldos. • Generación de respaldos automatizados, cifrados e inmutables, almacenados en una ubicación geográficamente distinta.

Fase de seguimiento

Para auditar el cumplimiento de los controles de seguridad establecidos en los casos de uso y abuso de la plataforma financiera, se aplicará el siguiente instrumento:

Tabla 8. Checklist de auditoría de seguridad.

Empresa: Sistema Web de Gestión de Portafolios
Área de objeto de estudio: Seguridad Lógica y Desarrollo
P/T: AU-SEC001
Objetivo de Control: Evaluar la efectividad de las medidas de mitigación contra accesos no autorizados y manipulación de datos.

Ítem	Sí	No	N/A
1. Existe un sistema de control de acceso que exige autenticación de doble factor (2FA) a los inversionistas.			
2. El sistema bloquea temporalmente las cuentas de usuario tras registrar tres intentos de inicio de sesión fallidos.			
3. Existe verificación y parametrización de las consultas a la base de datos para evitar Inyección SQL en la visualización de saldos.			
4. La aplicación valida estrictamente los montos de entrada en el registro de operaciones financieras (aportaciones/retiros).			
5. Se generan logs de auditoría inmutables para cada transacción financiera exitosa o rechazada.			
6. Toda la información del portafolio se transmite de cliente a servidor mediante protocolos de canal seguro (TLS 1.3).			

CONCLUSIÓN.

Finalmente, como se ha logrado evidenciar en este proyecto, la transición de un Ciclo de Vida de Desarrollo de Software (SDLC) tradicional hacia un enfoque de desarrollo seguro implica una reestructuración profunda en las fases operativas, administrativas y de ingeniería de cualquier organización. Esta evolución exige concientización y la implementación estricta de controles de seguridad desde el levantamiento de los requisitos funcionales y no funcionales. Dichas consideraciones deben mantenerse presentes a lo largo de todas las ceremonias operativas (reuniones diarias, planeación de sprints y revisiones). Si bien en este caso el modelo se adaptó bajo el marco de trabajo Agile/Scrum, es imperativo reconocer que estos principios son universales y totalmente aplicables a otras metodologías ágiles como Kanban o XP.

Asimismo, es importante destacar que el auge de la cultura y el stack de herramientas DevOps —especialmente mediante pipelines de integración y despliegue continuo (CI/CD)— ha logrado que las operaciones de desarrollo y mantenimiento sean mucho más fluidas y flexibles ante los cambios abruptos inherentes a cualquier proyecto de software. Para alcanzar este nivel de madurez, es fundamental consolidar una cohesión total entre los equipos de Desarrollo, Operaciones y Seguridad (DevSecOps). Al lograr esta sinergia, la seguridad deja de ser una fase aislada al final del desarrollo para convertirse en un pilar transversal que inyecta valor, mitigación de riesgos y resiliencia al producto desde su concepción hasta su despliegue en producción.

REFERENCIAS BIBLIOGRÁFICAS.

- Hernández, M., y Baquero, L. (2020). Ciclo de desarrollo ágil de software seguro. Los Libertadores Fundación Universitaria.
- Universidad Autónoma de Guadalajara. (s.f.). Guía de proyecto integrador: Desarrollo de Software Seguro [Archivo PDF].
- MKLabs. (2026). StarUML (Versión 6.0) [Software de modelado]. <https://staruml.io/>